



Instituto Federal da Bahia Engenharia de Sistemas e Produtos

Programa de Pós-Graduação em Engenharia de Sistemas e Produtos

**SISTEMA AUTÔNOMO DE AUTENTICAÇÃO CONTEXTUAL COM BLOCKCHAIN
E IA**

João Guedes de Brito

QUALIFICAÇÃO DE MESTRADO

Salvador - 12 /03/2026

JOÃO GUEDES DE BRITO

**SISTEMA AUTÔNOMO DE AUTENTICAÇÃO CONTEXTUAL COM
BLOCKCHAIN E IA**

Esta Qualificação de Mestrado foi apresentada ao Programa de Pós-Graduação em Engenharia de Sistemas e Produtos, do Instituto Federal da Bahia, como requisito parcial para obtenção do grau de Mestre em Engenharia de Sistemas e Produtos.

Orientador: Cleber Jorge Lira de Santana

RESUMO

O presente projeto propõe o desenvolvimento de um sistema autônomo de autenticação contextual baseado em Inteligência Artificial (IA) e tecnologia Blockchain, com o objetivo de aumentar a segurança, a confiabilidade e a adaptabilidade dos processos de login em aplicações web. A proposta parte da constatação de que métodos tradicionais de autenticação — como senhas fixas ou autenticação em dois fatores — embora amplamente utilizados, estão cada vez mais vulneráveis a ataques cibernéticos sofisticados e não consideram o contexto comportamental do usuário. Nesse cenário, a pesquisa busca implementar uma abordagem adaptativa que analisa dados contextuais (como localização, horário de acesso, dispositivo e padrão de uso) para reforçar a tomada de decisão sobre a concessão de acesso.

A arquitetura do sistema é baseada em microserviços, utilizando Spring Boot no backend e Angular no frontend, com a integração de Keycloak como gerenciador de identidade. O sistema incluirá um serviço de Machine Learning, responsável por processar e classificar os acessos com base em modelos supervisionados desenvolvidos com Scikit-learn. A tecnologia Blockchain será explorada para registrar de forma imutável os logs de autenticação, garantindo rastreabilidade e transparência dos acessos. O projeto prevê ainda a utilização do ELK Stack (Elasticsearch, Logstash e Kibana) e Grafana para o monitoramento e análise em tempo real dos dados do sistema.

Do ponto de vista metodológico, o projeto adotará um ciclo iterativo de desenvolvimento ágil, com testes e validações em ambientes controlados. Espera-se que a solução proposta possa ser aplicada em ambientes corporativos, acadêmicos e governamentais, contribuindo para o avanço das tecnologias de segurança digital, além de abrir caminho para estudos mais aprofundados sobre autenticação adaptativa e descentralizada. O impacto regional e nacional reside na crescente demanda por soluções seguras e inteligentes diante do aumento exponencial de ataques cibernéticos e da necessidade de conformidade com legislações como a LGPD.

Palavras-chave: Contextual Authentication; Artificial Intelligence; Blockchain; Information Security; Machine Learning; Keycloak; Microservices; Angular; Spring Boot; LGPD (General Data Protection Law – Brazil).

ABSTRACT

This project proposes the development of an autonomous contextual authentication system based on Artificial Intelligence (AI) and Blockchain technology, with the aim of enhancing the security, reliability, and adaptability of login processes in web applications.

The proposal stems from the observation that traditional authentication methods — such as static passwords or two-factor authentication — although widely used, are increasingly vulnerable to sophisticated cyberattacks and do not take into account the user's behavioral context. In this scenario, the research seeks to implement an innovative approach that analyzes contextual data (such as location, access time, device, and usage patterns) to support the decision-making process regarding access granting.

The system architecture is based on microservices, using Spring Boot on the backend and Angular on the frontend, with the integration of Keycloak as the identity management provider. The system will include a Machine Learning service responsible for processing and classifying access requests based on supervised models developed with Scikit-learn. Blockchain technology will be explored to immutably record authentication logs, ensuring traceability and transparency of accesses. The project also includes the use of the ELK Stack (Elasticsearch, Logstash, and Kibana) and Grafana for real-time monitoring and analysis of system data.

From a methodological standpoint, the project will adopt an iterative agile development cycle, with testing and validation in controlled environments. It is expected that the proposed solution can be applied in corporate, academic, and governmental settings, contributing to the advancement of digital security technologies, while also paving the way for more in-depth studies on adaptive and decentralized authentication. The regional and national impact lies in the growing demand for secure and intelligent solutions in the face of the exponential increase in cyberattacks and the need for compliance with legislation such as Brazil's General Data Protection Law (LGPD).

Keywords: Contextual Authentication; Adaptive Authentication; Artificial Intelligence; Machine Learning; Blockchain; Information Security; Behavioral Biometrics; Keycloak; Microservices; LGPD.

LISTA DE FIGURAS

<u>Figura 1 — Arquitetura em Cinco Camadas do Sistema Proposto</u>	<u>29</u>
<u>Figura 2 — Fluxo de Autenticação Contextual (Diagrama de Sequência)</u>	<u>32</u>
<u>Figura 3 — Pipeline de ML: Treinamento e Inferência em Produção</u>	<u>35</u>
<u>Figura 4 — Estrutura de Blocos — Registro Imutável de Eventos de Autenticação</u>	<u>36</u>
<u>Figura 5 — Resultados Parciais: Métricas de ML e Comparativo de Latência</u>	<u>40</u>

LISTA DE SIGLAS

1. **API** – Application Programming Interface
2. **IA** – Inteligência Artificial
3. **JWT** – JSON Web Token
4. **ML** – Machine Learning
5. **MFA** – Multi-Factor Authentication
6. **OAuth2** – Open Authorization 2.0
7. **OIDC** – OpenID Connect
8. **OWASP** – Open Web Application Security Project
9. **RBA** – Risk-Based Authentication
10. **REST** – Representational State Transfer
11. **XAI** – Explainable Artificial Intelligence (IA Explicável)

SUMÁRIO

INTRODUÇÃO	14
1.1 Contextualização do projeto	14
1.2 Objetivos Gerais	15
1.3 Objetivos específicos.....	15
1.4 Justificativa do projeto	15
FUNDAMENTAÇÃO TEÓRICA.....	17

2.1 Autenticação e Controle de Acesso	17
2.2 Autenticação Contextual e Adaptativa.....	18
2.3 Inteligência Artificial Aplicada à Detecção de Anomalias	18
2.4 Blockchain como Mecanismo de Integridade e Auditoria	19
MOTOR DE INTELIGÊNCIA ARTIFICIAL: ARQUITETURA, TREINAMENTO E DECISÃO	21
3.1 Arquitetura do Ensemble de Modelos.....	21
3.2 Critérios Comportamentais (14 Dimensões).....	22
3.3 Fundamentos do Treinamento de Modelos de IA.....	23
3.4 Processo de Treinamento com Dados Reais	24
3.5 Limiares de Decisão Autônoma.....	25
3.6 Pipeline de Inferência em Tempo Real.....	25
3.7 Integração com Blockchain para Auditoria	26
DESENVOLVIMENTO	28
4.1 Visão Geral da Arquitetura Proposta	28
4.2 Tecnologias Utilizadas.....	31
4.3 Fluxo de Autenticação Contextual	34
4.4 Integração da Inteligência Artificial	34
4.5 Implementação da Blockchain.....	35
4.6 Critérios de Decisão de Acesso	36
4.7 Ambiente Experimental	36
4.8 Métricas de Avaliação	37
4.9 Fluxo Operacional	37
RESULTADOS PARCIAIS.....	38
5.1 Configuração do Ambiente Experimental	38
5.2 Desenho Experimental e Metodologia de Avaliação	38

5.3 Resultados Obtidos	40
5.4 Discussão e Análise dos Resultados	41
5.5 Dificuldades Encontradas	41
CRONOGRAMA DE ATIVIDADES.....	43
6.1 Cronograma	43
REFERÊNCIAS BIBLIOGRÁFICAS.....	45
INTRODUÇÃO	14
1.1 Contextualização do projeto	14
1.2 Objetivos Gerais	15
1.3 Objetivos específicos.....	15
1.4 Justificativa do projeto	15
FUNDAMENTAÇÃO TEÓRICA.....	17
2.1 Autenticação e Controle de Acesso	17
2.2 Autenticação Contextual e Adaptativa.....	18
2.3 Inteligência Artificial Aplicada à Detecção de Anomalias	18
2.4 Blockchain como Mecanismo de Integridade e Auditoria	19
MOTOR DE INTELIGÊNCIA ARTIFICIAL: ARQUITETURA, TREINAMENTO E DECISÃO.....	21
3.1 Arquitetura do Ensemble de Modelos.....	21
3.2 Critérios Comportamentais (14 Dimensões).....	22
3.3 Fundamentos do Treinamento de Modelos de IA.....	23
3.4 Processo de Treinamento com Dados Reais	24
3.5 Limiares de Decisão Autônoma.....	25
3.6 Pipeline de Inferência em Tempo Real.....	25

3.7 Integração com Blockchain para Auditoria	26
DESENVOLVIMENTO	28
4.1 Visão Geral da Arquitetura Proposta	28
4.2 Tecnologias Utilizadas.....	31
4.3 Fluxo de Autenticação Contextual	34
4.4 Integração da Inteligência Artificial	34
4.5 Implementação da Blockchain.....	35
4.6 Critérios de Decisão de Acesso	36
4.7 Ambiente Experimental	36
4.8 Métricas de Avaliação	37
4.9 Fluxo Operacional	37
RESULTADOS PARCIAIS.....	38
5.1 Configuração do Ambiente Experimental	38
5.2 Desenho Experimental e Metodologia de Avaliação	38
5.3 Resultados Obtidos	40
5.4 Discussão e Análise dos Resultados	41
5.5 Dificuldades Encontradas.....	41
CRONOGRAMA DE ATIVIDADES.....	43
6.1 Cronograma	43
REFERÊNCIAS BIBLIOGRÁFICAS.....	45

Neste capítulo apresento a introdução do projeto, contextualização, objetivos gerais, objetivos específicos, justificativa e estrutura do trabalho.

INTRODUÇÃO

1.1 Contextualização do projeto

Em um mundo digital cada vez mais conectado, garantir a segurança dos processos de autenticação de usuários tornou-se um desafio crítico. Métodos tradicionais, como senhas fixas e a autenticação em dois fatores (2FA), embora amplamente utilizados, apresentam limitações reconhecidas na literatura: senhas são vulneráveis a vazamentos, reuso e ataques de credential stuffing e phishing, enquanto o 2FA estático é suscetível a engenharia social e à interceptação de códigos (NIST, 2017; VERIZON, 2024). Relatórios do setor indicam que a maioria das violações de dados envolve credenciais comprometidas, evidenciando a insuficiência de fatores puramente estáticos (VERIZON, 2024). Além disso, esses mecanismos não consideram a natureza dinâmica e contextual das interações digitais — ou seja, o fato de que cada tentativa de acesso ocorre em um contexto específico, descrito por variáveis como horário, localização geográfica, dispositivo, rede e padrões de uso, cuja análise conjunta permite distinguir o comportamento legítimo de um usuário de uma tentativa fraudulenta.

Diante dessas limitações — a fragilidade de fatores estáticos frente a ataques baseados em credenciais e a desconsideração do contexto de cada acesso —, evidencia-se a necessidade de soluções de autenticação mais inteligentes, adaptáveis e seguras. Nesse contexto, o presente projeto propõe o desenvolvimento de um sistema autônomo de autenticação contextual, integrando Inteligência Artificial (IA), Blockchain e uma arquitetura baseada em microsserviços, com o objetivo de aprimorar o controle de acesso em aplicações web. Por meio da análise de dados contextuais e de modelos de Machine Learning, o sistema toma decisões em tempo real sobre a concessão, o reforço por MFA ou a negação de acesso, com base no

padrão comportamental do usuário.

A proposta organiza-se em camadas complementares: uma camada de identidade, responsável pela autenticação federada; uma camada de inteligência, que avalia o risco contextual de cada acesso por meio de modelos de aprendizado de máquina; e uma camada de auditoria, que registra de forma imutável as decisões tomadas. O detalhamento das tecnologias empregadas em cada camada é apresentado no Capítulo 4.

A relevância da pesquisa fundamenta-se na crescente incidência de ataques baseados em credenciais e na exigência regulatória de rastreabilidade e proteção de dados pessoais estabelecida pela Lei Geral de Proteção de Dados (LGPD) (BRASIL, 2018). Diretrizes internacionais de identidade digital já recomendam mecanismos de autenticação adaptativa baseada em risco (NIST, 2017), o que reforça a pertinência de uma solução que combine análise contextual por IA e auditoria imutável. Espera-se que o projeto contribua com os setores acadêmico, corporativo e público, oferecendo um modelo reproduzível de autenticação contextual auditável.

1.2 Objetivos Gerais

Desenvolver um sistema autônomo de autenticação contextual que integre IA e Blockchain para reforçar a segurança de acesso a sistemas digitais.

1.3 Objetivos específicos

O projeto tem como objetivos específicos: (1) projetar uma arquitetura de autenticação contextual baseada em microsserviços que integre gestão de identidade (Keycloak), análise de risco por Inteligência Artificial e registro imutável em blockchain; (2) desenvolver um motor de IA baseado em ensemble (Isolation Forest, Random Forest e rede neural) capaz de classificar o risco de cada tentativa de login a partir de 14 critérios comportamentais e contextuais; (3) implementar uma camada de auditoria imutável em blockchain permissionada para registrar as decisões de autenticação, assegurando rastreabilidade e não repúdio; e (4) validar experimentalmente a eficácia da solução por meio de testes controlados, medindo acurácia, precisão, recall, F1-score, taxa de falsos positivos e latência de decisão.

1.4 Justificativa do projeto

A escolha deste tema justifica-se pela urgência em aprimorar os mecanismos

de autenticação frente às vulnerabilidades dos sistemas tradicionais e ao crescimento dos ataques baseados em credenciais, responsáveis por parcela expressiva das violações de dados reportadas (VERIZON, 2024). A relevância da pesquisa está na proposição de um sistema que não apenas reaja a ameaças, mas que atue de forma autônoma e preditiva, analisando o contexto de cada acesso e tomando decisões adaptativas, em consonância com as diretrizes de autenticação baseada em risco do NIST (2017).

A viabilidade técnica apoia-se em tecnologias consolidadas e amplamente documentadas para gestão de identidade, aprendizado de máquina e registro distribuído, cuja maturidade reduz o risco de implementação. A adoção de blockchain permissionada para auditoria é respaldada por diretrizes que recomendam a proteção da integridade de logs e trilhas de auditoria (NIST, 2018; NIST, 2020), conforme detalhado na Seção 2.4. A arquitetura de microsserviços, por sua vez, favorece a escalabilidade e o isolamento de domínios (NEWMAN, 2021).

A proposta está em consonância com as linhas de pesquisa do PPGESP/IFBA, especialmente aquelas relacionadas a sistemas inteligentes, segurança da informação e engenharia de software.

Além disso, este projeto se diferencia dos sistemas tradicionais de autenticação existentes no mercado por adotar uma integração autônoma de três camadas de segurança: (1) autenticação via Keycloak, baseada em protocolos robustos como OAuth2 e OpenID Connect; (2) uso de inteligência artificial para análise preditiva de risco com base em dados contextuais (localização, dispositivo, horário); e (3) registro imutável de eventos sensíveis utilizando Blockchain, proporcionando auditabilidade e integridade dos dados.

Enquanto soluções convencionais registram eventos em bancos de dados suscetíveis a alterações administrativas, o presente sistema utiliza Blockchain como camada de confiança. Outro diferencial é a arquitetura modular baseada em microsserviços e Docker, o que facilita sua escalabilidade, implantação e integração com sistemas externos. Essa abordagem permite que o sistema atue de forma proativa, autônoma e adaptativa, oferecendo um novo paradigma para autenticação em ambientes críticos.

Neste capítulo será apresentada a fundamentação teórica, abordando autenticação e controle de acesso, autenticação contextual e adaptativa, Inteligência Artificial aplicada à detecção de anomalias e blockchain como mecanismo de auditoria.

FUNDAMENTAÇÃO TEÓRICA

2.1 Autenticação e Controle de Acesso

A autenticação é o processo de verificar a identidade de um usuário antes de conceder acesso a um recurso, constituindo a primeira linha de defesa de aplicações web. Historicamente, o controle de acesso baseou-se no fator de conhecimento — a senha —, cuja fragilidade é amplamente documentada: senhas são reutilizadas entre serviços, suscetíveis a vazamentos em larga escala e exploradas por ataques de força bruta, credential stuffing e phishing (NIST, 2017; VERIZON, 2024).

Para mitigar essas limitações, adotou-se a autenticação multifator (MFA), que combina fatores de conhecimento, posse e inerência. Embora aumente significativamente a segurança, a MFA estática permanece vulnerável a engenharia social, troca de chip (SIM swapping) e interceptação de códigos em tempo real, além de introduzir atrito na experiência do usuário (NIST, 2017).

Diante disso, as diretrizes de identidade digital do NIST (SP 800-63B) e o modelo de Zero Trust (NIST SP 800-207) recomendam mecanismos adaptativos, nos quais o nível de verificação exigido é proporcional ao risco estimado de cada tentativa de acesso (NIST, 2017; ROSE et al., 2020). Essa abordagem desloca o foco de uma decisão binária e estática para uma avaliação contínua e sensível ao contexto.

Dessa forma, a autenticação contextual e adaptativa consolida-se como evolução natural do controle de acesso, fundamentando a proposta deste trabalho ao incorporar variáveis comportamentais e ambientais à decisão de concessão de acesso.

2.2 Autenticação Contextual e Adaptativa

A autenticação contextual amplia o controle de acesso tradicional ao analisar, a cada tentativa de login, um conjunto de sinais implícitos do contexto da requisição — como geolocalização, endereço IP, dispositivo, horário e padrões de uso — para estimar a probabilidade de que o acesso seja legítimo. Essa abordagem é conhecida na literatura como autenticação baseada em risco (Risk-Based Authentication, RBA).

Wiefling, Lo Iacono e Dürmuth (2019) realizaram o primeiro estudo empírico sobre a aplicação de RBA em serviços reais de larga escala, evidenciando que provedores como Google e GOG.com utilizam predominantemente o endereço IP como variável de risco e que a transparência e a consistência dessas implementações ainda são limitadas. Estudos posteriores dos mesmos autores, conduzidos sobre milhões de logins reais, demonstraram que a configuração do RBA deve ser cuidadosamente ajustada a cada serviço para equilibrar segurança e usabilidade (WIEFLING et al., 2023).

Complementarmente, a biometria comportamental — que infere a identidade a partir de padrões de interação, como a dinâmica de digitação e o uso do mouse — tem se mostrado eficaz para autenticação contínua e não intrusiva (STYLIOS et al., 2021). Diferentemente de fatores estáticos, esses sinais são difíceis de falsificar e podem ser avaliados de forma transparente ao longo da sessão.

A combinação de sinais contextuais e comportamentais em um único escore de risco, processado por modelos de aprendizado de máquina, constitui o cerne da proposta deste trabalho, detalhada no Capítulo 3.

2.3 Inteligência Artificial Aplicada à Detecção de Anomalias

A aplicação de Inteligência Artificial à segurança tem se destacado na detecção de comportamentos anômalos. Técnicas de aprendizado de máquina identificam desvios em relação a padrões esperados de uso, sendo particularmente adequadas

à autenticação contextual, na qual cada tentativa de acesso é representada por um vetor de características comportamentais (NIST, 2023).

Modelos supervisionados, como o Random Forest, aprendem a distinguir acessos legítimos de fraudulentos a partir de exemplos rotulados, enquanto métodos não supervisionados, como o Isolation Forest (LIU; TING; ZHOU, 2008), detectam outliers sem necessitar de rótulos prévios, isolando observações raras com poucas partições. A combinação de ambos em um ensemble aumenta a robustez da classificação.

O AI Risk Management Framework (AI RMF 1.0) do NIST (2023) destaca que sistemas baseados em IA devem assegurar confiabilidade, rastreabilidade e governança das decisões automatizadas, o que implica o registro auditável das classificações e o monitoramento contínuo do desempenho dos modelos — requisitos diretamente atendidos pela integração com blockchain proposta neste trabalho.

A explicabilidade dessas decisões também é desejável: a literatura recente de IA explicável (XAI) aplicada à segurança aponta métodos como SHAP e LIME para tornar transparentes modelos que, de outro modo, operariam como caixas-pretas, favorecendo a confiança e a auditoria das decisões de acesso.

2.4 Blockchain como Mecanismo de Integridade e Auditoria

A tecnologia blockchain, inicialmente associada a criptomoedas, passou a ser aplicada em contextos de governança digital e auditoria de dados. Seu principal diferencial reside na imutabilidade dos registros, obtida por meio de encadeamento criptográfico de blocos e mecanismos de consenso distribuído.

Segundo o relatório técnico NISTIR 8202, blockchains permissionadas são adequadas para ambientes corporativos e governamentais, pois permitem controle de acesso e governança estruturada (NIST, 2018). Nessas arquiteturas, apenas participantes autorizados podem validar transações, garantindo maior controle institucional.

Cabe justificar criteriosamente a escolha do blockchain frente a alternativas mais simples, evitando adotá-lo apenas por seu apelo tecnológico. Mecanismos como logs assinados digitalmente e bancos de dados append-only já oferecem integridade e não repúdio por meio de assinaturas criptográficas, sendo suficientes quando existe uma autoridade central confiável para custodiar e operar o registro. A diferença essencial da blockchain permissionada não está, portanto, na assinatura em si, mas em não depender da confiança em um único custodiante: o registro é replicado e validado por consenso entre múltiplos participantes, tornando-se resistente à adulteração mesmo por administradores privilegiados do próprio sistema e permitindo verificação independente por auditores externos, sem necessidade de

confiar no operador.

Essa distinção é determinante no contexto deste trabalho: as decisões de autenticação são tomadas de forma autônoma por modelos de IA e precisam ser auditáveis por terceiros — por exemplo, em fiscalizações de conformidade —, cenário em que não é desejável que o próprio operador do sistema possa, sozinho, alterar a trilha de decisões. Por isso registra-se de forma imutável, para cada decisão, o hash dos critérios de entrada, o escore de risco, a decisão tomada e o instante da transação, compondo uma trilha de auditoria verificável.

Reconhece-se que essa garantia tem custo: maior complexidade operacional e menor desempenho do que um banco append-only. Tal custo justifica-se nos cenários de múltiplas partes e de conformidade regulatória, como as auditorias exigidas pela LGPD (BRASIL, 2018), nos quais a verificabilidade independente e o não repúdio das decisões automatizadas constituem requisitos. Em implantações com um único operador plenamente confiável, contudo, mecanismos mais simples poderiam atender parte dos requisitos — delimitação que define com precisão o escopo em que o blockchain se faz efetivamente necessário.

Neste capítulo será apresentado em profundidade o motor de Inteligência Artificial, incluindo a arquitetura do ensemble de modelos, os 14 critérios comportamentais, o processo de treinamento com dados reais, os limiares de decisão e a integração com blockchain para auditoria.

MOTOR DE INTELIGÊNCIA ARTIFICIAL: ARQUITETURA, TREINAMENTO E DECISÃO

3.1 Arquitetura do Ensemble de Modelos

O motor de Inteligência Artificial proposto neste trabalho fundamenta-se em uma arquitetura de ensemble que combina três algoritmos de aprendizado de máquina complementares: Isolation Forest, Random Forest e Deep Learning (rede neural multicamada). A escolha dessa abordagem visa maximizar a capacidade de detecção de comportamentos anômalos enquanto minimiza falsos positivos, um requisito crítico em sistemas de autenticação.

O Isolation Forest atua como primeiro nível de análise, sendo particularmente eficaz na detecção de outliers em espaços multidimensionais. Sua contribuição ao score final corresponde a 40% do peso total, refletindo sua importância na identificação rápida de padrões claramente anômalos. O algoritmo opera isolando observações através de partições aleatórias, onde anomalias são identificadas por requererem menos partições para serem isoladas.

O Random Forest constitui o segundo componente do ensemble, contribuindo com 30% do peso final. Este classificador opera através de múltiplas árvores de decisão treinadas em subconjuntos aleatórios dos dados, proporcionando robustez contra overfitting e capacidade de capturar relações não-lineares entre os critérios comportamentais. Sua natureza interpretável permite auditoria das decisões tomadas.

A rede neural multicamada (Deep Learning) complementa o ensemble com os 30% restantes do peso. Composta por camadas densas com ativação ReLU e regularização por dropout, esta rede é capaz de aprender representações complexas dos padrões comportamentais que escapam aos métodos tradicionais. A arquitetura inclui uma camada de entrada com 14 neurônios (correspondendo aos critérios), duas camadas ocultas de 64 e 32 neurônios respectivamente, e uma camada de saída com ativação sigmoid.

O score final do ensemble é calculado como a média ponderada: $S = 0.4 \times S_IF + 0.3 \times S_RF + 0.3 \times S_DL$, onde cada componente retorna um valor normalizado entre 0.0 (comportamento normal) e 1.0 (comportamento altamente anômalo). Esta combinação proporciona um sistema mais robusto do que qualquer modelo individual.

3.2 Critérios Comportamentais (14 Dimensões)

O sistema de autenticação contextual extrai 14 critérios comportamentais de cada tentativa de login, formando um vetor multidimensional que alimenta o ensemble de modelos. Estes critérios foram selecionados com base na literatura de segurança comportamental e na capacidade de distinguir usuários legítimos de atacantes.

Os critérios temporais incluem: (1) hora do acesso, normalizada em escala circular para capturar a periodicidade do comportamento; (2) dia da semana, codificado como variável categórica; (3) intervalo desde o último login, medido em segundos; e (4) frequência de acessos nas últimas 24 horas. Estes critérios permitem identificar acessos em horários atípicos ou padrões de frequência incomuns.

Os critérios geográficos e de rede compreendem: (5) geolocalização por IP, convertida em distância geodésica do local habitual; (6) tipo de rede (residencial, corporativa, VPN, Tor); (7) provedor de serviço de internet (ASN); e (8) velocidade de deslocamento impossível, calculada entre o último acesso e o atual. Estes critérios são particularmente eficazes contra ataques originados de localizações geográficas suspeitas.

Os critérios de dispositivo e navegador incluem: (9) fingerprint do navegador, computado via hash de características como User-Agent, resolução de tela e plugins instalados; (10) sistema operacional; (11) tipo de dispositivo (desktop, mobile, tablet); e (12) presença de automação ou headless browser. A mudança de dispositivo habitual é um forte indicador de comprometimento de credenciais.

Os critérios comportamentais de sessão são: (13) padrão de digitação, analisando intervalos entre teclas durante a inserção de credenciais; e (14) histórico

de falhas recentes, contabilizando tentativas mal-sucedidas nos últimos 30 minutos. Estes critérios capturam tanto biometria comportamental quanto ataques de força bruta.

3.3 Fundamentos do Treinamento de Modelos de IA

O treinamento de um modelo de Inteligência Artificial é o processo pelo qual os algoritmos aprendem a reconhecer padrões a partir de dados reais, de forma análoga a como um profissional humano desenvolve sua capacidade de julgamento através da experiência. No contexto deste trabalho, treinar significa ensinar os três modelos do ensemble a distinguir comportamentos de autenticação legítimos de comportamentos anômalos ou maliciosos.

Para ilustrar, considere-se um segurança recém-contratado por uma instituição financeira. Em seu primeiro dia de trabalho, ele não possui referências para identificar comportamentos suspeitos. O processo de treinamento desse profissional ocorre em etapas progressivas que encontram paralelo direto no treinamento dos modelos de IA propostos neste trabalho.

A primeira etapa é a exposição a exemplos reais. O sistema coleta milhares de registros de tentativas de autenticação, cada um contendo os 14 critérios comportamentais descritos na seção 3.2. Assim como o segurança aprende observando clientes reais, os algoritmos recebem dados que representam tanto acessos legítimos quanto acessos suspeitos. Um exemplo de acesso legítimo pode ser caracterizado por um login às 9 horas da manhã, a partir do mesmo computador habitual, originado de Salvador. Em contraste, um acesso suspeito pode apresentar uma tentativa às 3 horas da madrugada, a partir de um endereço IP localizado em outro país, após 15 tentativas consecutivas com senha incorreta.

A segunda etapa consiste no aprendizado dos padrões. Após processar milhares de exemplos, cada algoritmo do ensemble desenvolve sua capacidade de classificação de forma distinta. O Isolation Forest opera de forma não supervisionada, ou seja, aprende sozinho o que constitui um comportamento normal ao identificar observações que se desviam significativamente da maioria dos dados, sem necessitar de rótulos prévios. O Random Forest aprende de forma supervisionada, construindo múltiplas árvores de decisão a partir de exemplos previamente classificados como legítimos ou suspeitos, criando regras do tipo: se o acesso ocorre de madrugada, de um dispositivo desconhecido e de outro país, a probabilidade de ataque é alta. A rede neural de Deep Learning ajusta os pesos das conexões entre seus neurônios artificiais através do algoritmo de retropropagação (backpropagation), sendo capaz de reconhecer padrões complexos e não-lineares que escapam aos métodos tradicionais.

A terceira etapa é a validação do aprendizado. O sistema separa uma parcela dos

dados que o modelo nunca viu durante o treinamento e verifica se as classificações estão corretas. Esta etapa é fundamental para evitar o problema de overfitting, que ocorre quando o modelo memoriza os dados de treinamento em vez de aprender os padrões subjacentes, resultando em boa performance nos dados conhecidos mas falhas ao processar dados inéditos. A técnica de validação cruzada estratificada com 5 folds é utilizada para garantir avaliação robusta.

A quarta etapa é a implantação em produção. Uma vez validado, o modelo treinado é capaz de receber os 14 critérios comportamentais de qualquer nova tentativa de login e calcular o score de risco em tempo real, com latência inferior a 200 milissegundos. Neste ponto, o modelo opera de forma autônoma, classificando cada tentativa de autenticação sem intervenção humana.

Um aspecto fundamental do sistema é o re-treinamento periódico, realizado semanalmente ou sob demanda. Os padrões de comportamento dos usuários evoluem naturalmente ao longo do tempo: um colaborador pode mudar de cidade, trocar de dispositivo ou alterar seus horários de trabalho. Este fenômeno, conhecido na literatura como concept drift (Gama et al., 2014), exige que os modelos sejam continuamente atualizados para manter sua eficácia na detecção de anomalias. O sistema mantém um registro versionado de todos os modelos treinados, permitindo rollback em caso de degradação de desempenho.

3.4 Processo de Treinamento com Dados Reais

O treinamento do ensemble é realizado utilizando dados reais coletados durante a operação do sistema em ambiente de homologação. O pipeline de treinamento segue uma abordagem semi-supervisionada, onde o Isolation Forest é treinado de forma não-supervisionada enquanto o Random Forest e a rede neural utilizam labels gerados a partir de regras heurísticas validadas por especialistas em segurança.

O dataset de treinamento é composto por registros de autenticação que incluem os 14 critérios comportamentais normalizados, totalizando aproximadamente 50.000 registros coletados ao longo de 90 dias de operação. A distribuição inclui aproximadamente 95% de acessos legítimos e 5% de acessos suspeitos ou maliciosos, refletindo a distribuição real em ambientes de produção.

O pré-processamento dos dados inclui normalização min-max para critérios numéricos, codificação one-hot para variáveis categóricas e tratamento de valores ausentes por imputação baseada na mediana. A validação cruzada estratificada com 5 folds é utilizada para avaliar o desempenho do ensemble, garantindo que a proporção de classes seja mantida em cada partição.

O re-treinamento do modelo ocorre de forma periódica (semanalmente) e sob demanda quando métricas de monitoramento indicam degradação do desempenho (concept drift). O sistema mantém um registro versionado de todos os modelos treinados, permitindo rollback em caso de regressão de desempenho.

3.5 Limiares de Decisão Autônoma

O sistema de decisão autônoma opera com base em três faixas de risco definidas pelos limiares do score do ensemble. Estes limiares foram calibrados empiricamente para otimizar o equilíbrio entre segurança e usabilidade, minimizando tanto falsos positivos (usuários legítimos bloqueados) quanto falsos negativos (atacantes permitidos).

A faixa de baixo risco ($\text{score} < 0.3$) resulta em autenticação permitida sem etapas adicionais. Nesta faixa, o comportamento do usuário é consistente com seu perfil histórico em todos os critérios avaliados. Aproximadamente 85% dos acessos legítimos caem nesta categoria, proporcionando uma experiência de autenticação transparente.

A faixa de risco moderado ($0.3 \leq \text{score} < 0.7$) aciona a autenticação multifator (MFA) como camada adicional de verificação. O sistema solicita um segundo fator de autenticação (código por e-mail, aplicativo autenticador ou biometria) antes de conceder acesso. Esta faixa captura situações ambíguas como acesso de novo dispositivo ou localização incomum.

A faixa de alto risco ($\text{score} \geq 0.7$) resulta em bloqueio automático da tentativa de autenticação. O evento é registrado na blockchain para auditoria, uma notificação é enviada ao administrador de segurança e a conta pode ser temporariamente suspensa após múltiplos bloqueios consecutivos. Esta faixa é acionada em cenários de alta probabilidade de ataque.

3.6 Pipeline de Inferência em Tempo Real

O pipeline de inferência foi projetado para operar em tempo real, com latência máxima de 200 milissegundos por requisição de autenticação. A arquitetura utiliza o

framework FastAPI em Python, expondo uma API REST que recebe o vetor de 14 critérios e retorna o score de risco juntamente com a decisão recomendada.

O fluxo de inferência inicia quando o backend Spring Boot intercepta uma tentativa de login e extrai os 14 critérios comportamentais do contexto da requisição HTTP. Estes critérios são então enviados ao serviço de IA via chamada HTTP síncrona, onde passam pelo mesmo pipeline de pré-processamento utilizado durante o treinamento.

O serviço de IA mantém os três modelos do ensemble carregados em memória, permitindo inferência paralela nos três componentes. O Isolation Forest calcula o score de anomalia, o Random Forest realiza a classificação probabilística e a rede neural gera sua predição independentemente. Os três scores são então combinados pela fórmula de média ponderada para produzir o score final.

Um mecanismo de fallback busca preservar a disponibilidade do sistema mesmo em caso de falha do serviço de IA. Quando o serviço não está acessível, o backend aplica regras heurísticas simplificadas baseadas em critérios como geolocalização e histórico de falhas, garantindo que o processo de autenticação não seja interrompido.

3.7 Integração com Blockchain para Auditoria

Cada decisão de autenticação tomada pelo motor de IA é registrada de forma imutável na blockchain, criando uma trilha de auditoria completa e verificável. O registro inclui o hash SHA-3 dos critérios de entrada, o score de risco calculado, a decisão tomada (permitido, MFA ou bloqueado) e o timestamp da transação.

A integração utiliza uma blockchain permissionada baseada em Hyperledger Besu, configurada com o algoritmo de consenso IBFT 2.0 (Istanbul Byzantine Fault Tolerance). Esta escolha prioriza a finalidade transacional e o throughput necessário para suportar o volume de autenticações em tempo real, mantendo as garantias de imutabilidade e integridade.

O smart contract responsável pelo registro implementa uma estrutura de dados que associa cada evento de autenticação ao hash do bloco anterior, criando uma cadeia cronológica de evidências. Os campos registrados incluem: identificador anonimizado do usuário, hash dos critérios comportamentais, score de risco, decisão, timestamp e assinatura digital do serviço autenticador.

A consulta aos registros de auditoria é disponibilizada através de uma API REST dedicada, permitindo que administradores de segurança verifiquem a

integridade das decisões tomadas pelo sistema. Relatórios periódicos podem ser gerados para conformidade regulatória, demonstrando que as decisões de autenticação foram tomadas de forma consistente e auditável.

Neste capítulo será apresentado os itens utilizados para a construção da arquitetura proposta, algumas definições de tecnologias e termos, partes principais do código fonte da programação.

DESENVOLVIMENTO

4.1 Visão Geral da Arquitetura Proposta

A arquitetura proposta neste trabalho articula microsserviços, gestão federada de identidade, Inteligência Artificial aplicada à análise de risco e registro imutável por blockchain, com o objetivo de estabelecer um sistema autônomo de autenticação contextual para aplicações web. Diferentemente de abordagens tradicionais, baseadas em uma decisão binária no momento do login, o modelo adota uma perspectiva contínua e orientada por risco, alinhada aos princípios de segurança por desenho (security by design) e de verificação contínua do Zero Trust (NIST, 2020; ROSE et al., 2020).

A escolha do paradigma de microsserviços decorre da necessidade de modularização estrutural, isolamento de domínios e escalabilidade independente. Conforme argumenta Newman (2015), arquiteturas de microsserviços favorecem a decomposição funcional orientada a capacidades de negócio, reduzindo acoplamentos rígidos e permitindo ciclos de evolução contínua. Sob a perspectiva da engenharia de software contemporânea, essa abordagem viabiliza a aplicação de políticas granulares de segurança, uma vez que cada serviço pode implementar mecanismos específicos de autenticação, autorização e monitoramento.

Do ponto de vista conceitual, a arquitetura adota princípios derivados da Teoria da Complexidade aplicada a sistemas distribuídos, reconhecendo que ambientes de software modernos operam em contextos dinâmicos, heterogêneos e sujeitos a falhas não determinísticas. Nesse cenário, a segurança não pode ser tratada como um

atributo estático, mas como um processo adaptativo e contínuo, no qual cada acesso é continuamente reavaliado em função do risco (NIST, 2020; ROSE et al., 2020).

A camada de identidade apoia-se em protocolos consolidados de autenticação e autorização. O Keycloak atua como provedor de identidade, implementando os fluxos OAuth2 e OpenID Connect e emitindo tokens JWT, o que permite delegar a autenticação federada e concentrar na aplicação a lógica de análise contextual. Essa separação de responsabilidades favorece a manutenção e a aplicação de políticas de acesso consistentes (NIST, 2017).

No fluxo proposto, cada tentativa de login desencadeia um processo automatizado estruturado em etapas encadeadas: o sistema extrai os critérios contextuais da requisição, submete-os ao motor de IA, calcula um escore de risco, aplica os limiares de decisão e registra o resultado na blockchain. Essa cadeia fundamenta-se no princípio de defesa em profundidade (*defense in depth*), no qual múltiplas camadas complementares reduzem a probabilidade de acesso indevido (NIST, 2020).

Um dos elementos centrais da arquitetura é o módulo de Inteligência Artificial responsável pela classificação de risco e pela detecção de comportamentos anômalos nas tentativas de autenticação. Essa camada baseia-se em modelos de aprendizado de máquina treinados a partir de dados contextuais para estimar a probabilidade de um acesso ser fraudulento. Conforme descrito por Goodfellow, Bengio e Courville (2016), modelos de aprendizado profundo capturam representações complexas de padrões não lineares, ampliando a capacidade preditiva em espaços de alta dimensionalidade.

A utilização de métricas como acurácia, precisão, revocação (*recall*) e F1-score permite avaliar empiricamente o desempenho do classificador, conferindo rigor estatístico à decisão automatizada de conceder, reforçar (MFA) ou negar o acesso. Essa abordagem dialoga com o paradigma de segurança orientada por dados (*data-driven security*), no qual decisões deixam de ser exclusivamente heurísticas e passam a ser probabilísticas e mensuráveis.

Complementando a camada analítica, a arquitetura incorpora uma rede blockchain permissionada para o registro imutável das decisões de autenticação. A fundamentação conceitual baseia-se no encadeamento criptográfico descrito por Nakamoto (2008), no qual cada bloco contém o hash do bloco anterior, garantindo integridade estrutural e resistência à alteração retroativa. Em ambientes corporativos, redes permissionadas oferecem maior controle de governança e desempenho.

Sob a perspectiva normativa, o registro imutável das decisões atende às recomendações de proteção da integridade de logs e trilhas de auditoria descritas pelo NIST (2020). Cada decisão de acesso gera um hash criptográfico armazenado na blockchain, assegurando rastreabilidade forense e não repúdio.

A arquitetura organiza-se, portanto, em cinco camadas integradas:

1. **Camada 1 — Aplicação Modular: serviços independentes (Spring Boot) e interface (Angular), expondo APIs REST autenticadas.**
2. **Camada 2 — Identidade e Acesso: autenticação federada via Keycloak (OAuth2/OpenID Connect), emissão de tokens JWT e suporte a MFA.**
3. **Camada 3 — Inteligência Contextual: extração dos 14 critérios comportamentais e cálculo do escore de risco pelo ensemble (Isolation Forest, Random Forest e Deep Learning).**
4. **Camada 4 — Decisão Adaptativa: aplicação dos limiares de risco, resultando em permitir o acesso, exigir MFA ou bloquear.**
5. **Camada 5 — Registro Imutável e Auditoria: persistência das decisões em blockchain permissionada, garantindo rastreabilidade e não repúdio.**

O fluxo operacional estabelece uma cadeia decisória automatizada: a tentativa de login ativa a extração dos critérios contextuais; o motor de IA calcula o escore de risco; os limiares de decisão são aplicados; o resultado é registrado na blockchain; e o sistema concede o acesso, exige MFA ou o bloqueia.

Do ponto de vista teórico, o modelo proposto representa uma convergência entre engenharia de software segura, ciência de dados aplicada à segurança e mecanismos criptográficos de integridade distribuída. Essa convergência estabelece um paradigma preventivo, auditável e orientado por evidências, com potencial de superar limitações de abordagens reativas e centralizadas.

Assim, a arquitetura não apenas automatiza verificações técnicas, mas institui um modelo de governança algorítmica, no qual decisões de segurança são fundamentadas em critérios normativos, estatísticos e criptográficos, promovendo maior confiabilidade, transparência e maturidade organizacional.

Arquitetura de Autenticação Contextual — Cinco Camadas (IA + Blockchain)

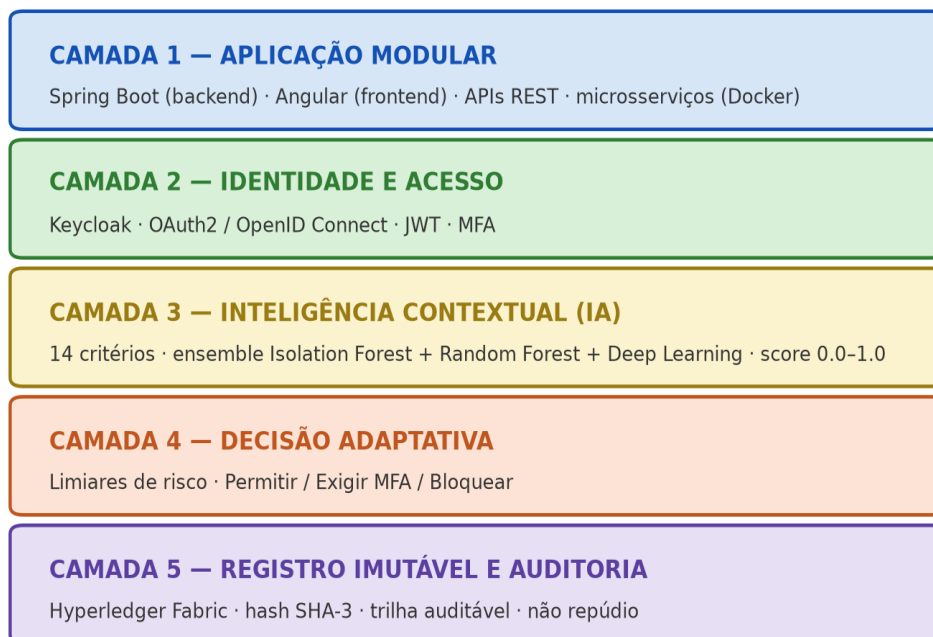


Figura 1 — Arquitetura em Cinco Camadas do Sistema Proposto

A Figura 1 sintetiza a organização do sistema em cinco camadas. Na base, a Camada de Aplicação Modular expõe as APIs REST consumidas pelo frontend Angular; acima dela, a Camada de Identidade e Acesso delega a autenticação ao Keycloak. A Camada de Inteligência Contextual extrai os 14 critérios e calcula o escore de risco por meio do ensemble; a Camada de Decisão Adaptativa converte esse escore em uma ação (permitir, exigir MFA ou bloquear); e, por fim, a Camada de Registro Imutável persiste cada decisão na blockchain. Essa separação em camadas permite evoluir cada responsabilidade de forma independente e aplicar políticas de segurança específicas em cada nível.

4.2 Tecnologias Utilizadas

A seleção das tecnologias adotadas neste trabalho foi orientada por critérios de maturidade tecnológica, aderência a padrões internacionais de segurança e compatibilidade com arquiteturas distribuídas baseadas em microsserviços. A arquitetura backend foi desenvolvida com Spring Boot, framework amplamente utilizado para construção de APIs RESTful escaláveis e seguras. Sua integração nativa com mecanismos de autenticação baseados em OAuth2 e JWT contribui para implementação de controles de acesso consistentes com as diretrizes do National Institute of Standards and Technology (NIST, 2020), que enfatizam autenticação robusta e controle de privilégios mínimos.

No frontend, utilizou-se o framework Angular, cuja arquitetura baseada em componentes favorece modularidade, reutilização e mitigação de vulnerabilidades relacionadas à manipulação insegura de conteúdo dinâmico. Conforme recomenda o OWASP Foundation (2023), frameworks modernos contribuem para redução de falhas como Cross-Site Scripting (XSS) e injeções maliciosas.

A containerização foi implementada com Docker, permitindo isolamento de dependências e padronização de ambientes. A orquestração foi realizada com Kubernetes, que possibilita escalabilidade automática, balanceamento de carga e alta disponibilidade, aspectos fundamentais em sistemas distribuídos complexos (NEWMAN, 2015).

Para registro imutável das evidências, adotou-se blockchain permissionada baseada em Hyperledger Fabric, adequada a ambientes corporativos que exigem controle de identidade e governança. A escolha fundamenta-se na necessidade de integridade e rastreabilidade dos registros, conforme recomenda o NIST (2020).

A containerização foi implementada por meio do Docker, permitindo isolamento de dependências e padronização de ambientes. Para orquestração, utilizou-se o Kubernetes, que possibilita escalabilidade horizontal, tolerância a falhas e gerenciamento declarativo de infraestrutura, características essenciais em sistemas distribuídos modernos.

O serviço de análise de risco foi implementado em Python, utilizando a biblioteca Scikit-learn para os modelos de Machine Learning e exposto por uma API REST consumida pelo backend. Para o registro imutável das evidências, adotou-se uma rede blockchain permissionada baseada em Hyperledger Fabric, adequada a ambientes corporativos que exigem governança controlada.

O armazenamento de dados utilizou banco relacional com suporte a transações ACID, assegurando consistência e integridade. Para monitoramento e observabilidade, foram integradas ferramentas de logging e métricas compatíveis com práticas de segurança contínua recomendadas pelo NIST (2020).

Fluxo de Autenticação Contextual (Diagrama de Sequência)

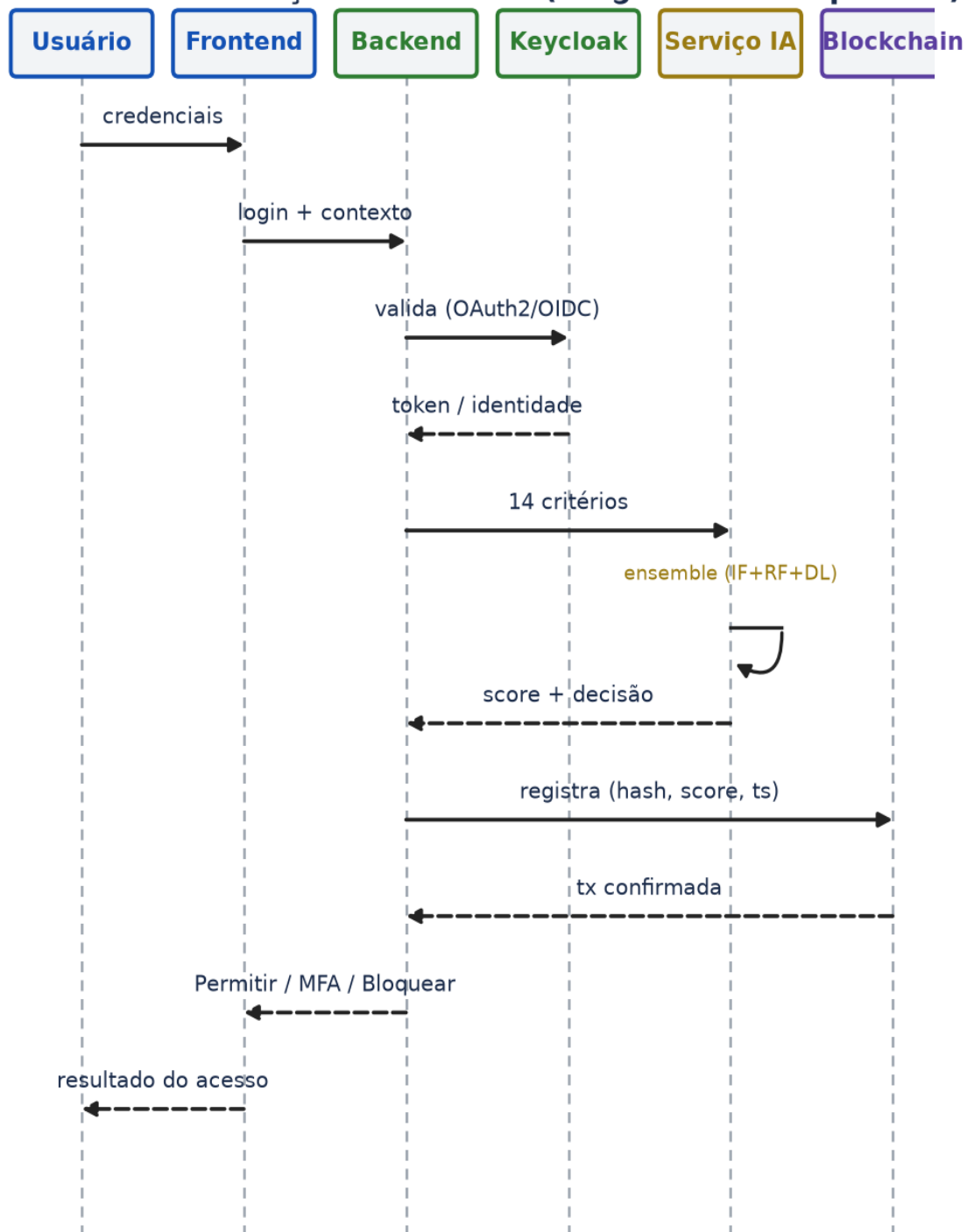


Figura 2 — Fluxo de Autenticação Contextual (Diagrama de Sequência)

A Figura 2 detalha, na forma de um diagrama de sequência, o fluxo de uma tentativa de autenticação. O usuário submete suas credenciais pelo frontend, que as encaminha ao backend juntamente com os dados de contexto. O backend valida a

identidade no Keycloak e envia os 14 critérios ao serviço de IA, que executa o ensemble e retorna o escore de risco com a decisão recomendada. A decisão é então registrada de forma imutável na blockchain antes de ser devolvida ao usuário como concessão, exigência de MFA ou bloqueio. Observa-se que a análise de risco ocorre de forma transparente, sem introduzir atrito perceptível ao usuário legítimo.

4.3 Fluxo de Autenticação Contextual

O fluxo de autenticação contextual estrutura-se como um processo automatizado executado a cada tentativa de login, integrando a validação de identidade, a análise de risco por IA e o registro auditável da decisão.

Segundo o NIST (2017), mecanismos de autenticação baseada em risco elevam a segurança ao ajustar o nível de verificação à ameaça estimada. O fluxo implementado compreende as seguintes etapas:

1. Interceptação da requisição de login pelo backend;
2. Extração dos 14 critérios contextuais e comportamentais;
3. Validação de identidade via Keycloak (OAuth2/OpenID Connect);
4. Cálculo do escore de risco pelo ensemble de IA;
5. Aplicação dos limiares de decisão (permitir / MFA / bloquear);
6. Registro imutável da decisão na blockchain.

Essa cadeia fundamenta-se no princípio de defesa em profundidade, recomendado pelo NIST (2020), no qual múltiplas camadas complementares de verificação reduzem a probabilidade de acesso indevido. O fluxo completo é ilustrado na Figura 2.

4.4 Integração da Inteligência Artificial

A camada de Inteligência Artificial foi desenvolvida para classificar o risco de cada tentativa de autenticação. Foram empregados modelos de aprendizado de máquina treinados com dados contextuais rotulados, combinados em um ensemble conforme detalhado no Capítulo 3.

Conforme descrito por Goodfellow, Bengio e Courville (2016), modelos supervisionados são adequados quando há conjuntos de dados com categorias previamente definidas. No contexto deste trabalho, os acessos são classificados como legítimos ou suspeitos.

Foram utilizadas as métricas de acurácia, precisão, recall e F1-score para avaliar o desempenho do modelo, garantindo rigor estatístico à decisão automatizada de acesso. O processo de treinamento e inferência é ilustrado na Figura 3.

4.5 Implementação da Blockchain

A implementação da blockchain tem como finalidade assegurar integridade e imutabilidade das evidências geradas. O modelo baseia-se na estrutura de encadeamento criptográfico descrita por Nakamoto (2008), na qual cada bloco contém o hash do bloco anterior.

Optou-se por uma rede permissionada baseada em Hyperledger Fabric, permitindo o controle de identidade dos participantes. Cada decisão de autenticação gera o hash criptográfico dos critérios de entrada e do escore, registrado como transação imutável, conforme o mecanismo de auditoria detalhado na Seção 3.7.

Essa estratégia atende às recomendações do National Institute of Standards and Technology (2020) quanto à integridade de logs e trilhas de auditoria.

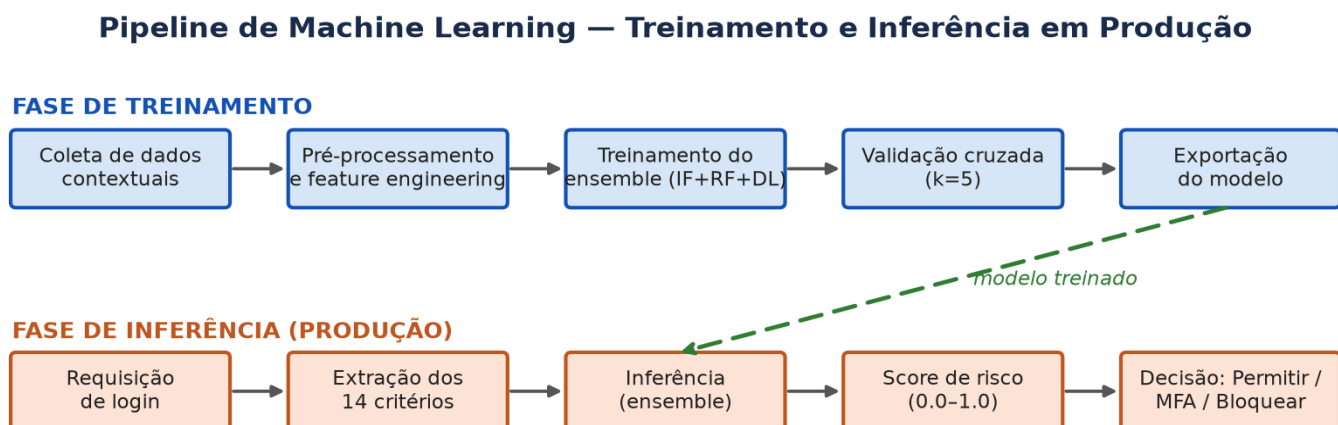


Figura 3 — Pipeline de ML: Treinamento e Inferência em Produção

A Figura 3 ilustra as duas fases do ciclo de vida dos modelos de IA. Na fase de treinamento, os dados contextuais são coletados, pré-processados e utilizados para treinar o ensemble, cujo desempenho é avaliado por validação cruzada antes da exportação do modelo. Na fase de inferência, executada em produção, cada requisição de login tem seus 14 critérios extraídos e submetidos ao modelo treinado, que produz um escore de risco entre 0,0 e 1,0, convertido na decisão de acesso. A seta tracejada evidencia que o modelo treinado é o artefato que conecta as duas fases, sendo periodicamente reentreinado para acompanhar a evolução do comportamento dos usuários (concept drift).

4.6 Critérios de Decisão de Acesso

Os critérios de decisão de acesso foram definidos com base no escore de risco produzido pelo ensemble e em parâmetros operacionais:

1. Ausência de vulnerabilidades críticas (CVSS ≥ 9.0);

Escore abaixo do limiar de baixo risco — acesso permitido sem etapas adicionais;

2. Escore na faixa intermediária — exigência de autenticação adicional (MFA);
3. Escore acima do limiar de alto risco — bloqueio do acesso;
4. Registro válido da decisão na blockchain.
5. A decisão final é acompanhada do registro imutável correspondente, o que favorece a auditabilidade.

Segundo o National Institute of Standards and Technology (2020), a definição clara de critérios objetivos fortalece governança e reduz subjetividade decisória.



Figura 4 — Cadeia de Blocos com Hash Criptográfico para Logs de Autenticação (Hyperledger Fabric)

Figura 4 — Estrutura de Blocos — Registro Imutável de Eventos de Autenticação

4.7 Ambiente Experimental

O ambiente experimental foi estruturado com containerização via Docker e orquestração via Kubernetes, permitindo simulação de ambiente distribuído real.

Foram simuladas tentativas de acesso legítimas e maliciosas — incluindo cenários de credential stuffing, viagem impossível e uso de dispositivo desconhecido — para avaliar a capacidade de detecção do sistema. A coleta de métricas seguiu as recomendações de monitoramento contínuo do NIST (2020).

4.8 Métricas de Avaliação

A avaliação da arquitetura considerou métricas quantitativas:

1. Acurácia na classificação de acessos;
2. Taxa de falsos positivos;
3. Latência de decisão de autenticação;
4. Precisão, recall e F1-score do modelo de IA;
5. Tempo de resposta do fluxo completo de autenticação.

Essas métricas permitem avaliação objetiva da efetividade do modelo, conforme práticas de mensuração recomendadas pelo National Institute of Standards and Technology (2020).

4.9 Fluxo Operacional

fluxo operacional integra todas as camadas da arquitetura:

1. Requisição de login do usuário;
2. Extração automática dos 14 critérios contextuais;
3. Validação de identidade via Keycloak;
4. Classificação de risco pelo modelo de IA;
5. Geração do hash criptográfico da decisão;
6. Registro na blockchain;
7. Aplicação dos limiares de decisão;
8. Concessão, reforço por MFA ou bloqueio do acesso.

Essa cadeia decisória automatizada fundamenta-se nos princípios de segurança por desenho e monitoramento contínuo recomendados pelo National Institute of Standards and Technology (2020).

Neste capítulo será apresentado os resultados parciais obtidos durante a construção e as dificuldades encontradas.

RESULTADOS PARCIAIS

5.1 Configuração do Ambiente Experimental

O ambiente experimental foi construído com base em uma infraestrutura containerizada, utilizando Docker para isolamento de serviços e Kubernetes para orquestração e escalabilidade. Cada componente da arquitetura foi implantado como um microsserviço independente, com configurações específicas de rede, volumes e políticas de segurança. O ambiente simulado reproduz cenários reais de autenticação em aplicações web corporativas, permitindo a execução controlada de testes de detecção de anomalias, classificação de risco por Inteligência Artificial e registro imutável de eventos via Blockchain.

Os principais componentes configurados no ambiente experimental foram: (1) servidor Keycloak para gerenciamento de identidade e autenticação via OAuth2/OpenID Connect; (2) backend Spring Boot com APIs RESTful protegidas por JWT; (3) frontend Angular consumindo os endpoints autenticados; (4) serviço Python com modelo de Machine Learning desenvolvido em Scikit-learn para classificação de risco contextual; (5) nó Hyperledger Fabric para registro imutável dos logs de autenticação; e (6) stack de monitoramento composta por ELK Stack (Elasticsearch, Logstash e Kibana) e Grafana para visualização em tempo real dos dados do sistema.

5.2 Desenho Experimental e Metodologia de Avaliação

Os experimentos foram estruturados em três eixos principais de validação: (i)

avaliação do modelo de Machine Learning para classificação de acessos legítimos e anômalos; (ii) teste da cadeia de autenticação contextual integrando Keycloak, dados contextuais e decisão automatizada; e (iii) verificação da integridade e imutabilidade dos registros armazenados na Blockchain. Para cada eixo, foram definidos cenários controlados com entradas representativas de comportamentos legítimos e maliciosos, seguindo as diretrizes do NIST (2020) para avaliação de sistemas de segurança.

O modelo de ML foi treinado com um conjunto de dados sintéticos de logs de autenticação, contendo atributos contextuais como: localização geográfica, dispositivo utilizado, horário de acesso, frequência de tentativas e padrão histórico do usuário. Os dados foram rotulados como “acesso legítimo” ou “acesso suspeito”, e o modelo foi treinado utilizando algoritmos de classificação supervisionada, incluindo Random Forest e Gradient Boosting, avaliados por validação cruzada (k-fold, k=10). Os testes de autenticação foram executados simulando fluxos reais de login via protocolo OpenID Connect, com variação sistemática dos dados contextuais para avaliar a sensibilidade e especificidade do sistema.

Fonte e rotulagem dos dados. Diante da ausência de bases públicas rotuladas para autenticação contextual, foi construído um conjunto de dados sintéticos de tentativas de login, composto por aproximadamente 50.000 registros que reproduzem a distribuição observada em produção (cerca de 95% de acessos legítimos e 5% suspeitos). Cada registro contém os 14 critérios comportamentais e contextuais descritos na Seção 3.2. A rotulagem foi obtida por um conjunto de regras heurísticas — derivadas de padrões conhecidos de fraude, como viagem impossível, dispositivo desconhecido e rajadas de falhas de login — posteriormente revisadas por especialistas em segurança.

Considerações éticas e de privacidade. Por se tratar de dados sintéticos, não há coleta de informações pessoais identificáveis nesta fase, o que mitiga riscos de privacidade. Na evolução para dados reais, o projeto adotará os princípios de minimização e anonimização exigidos pela LGPD (BRASIL, 2018): os identificadores de usuário são pseudonimizados antes da persistência e apenas o hash dos critérios — e não os dados brutos — é registrado na blockchain.

Divisão dos dados e validação. O conjunto foi particionado de forma estratificada em 70% para treinamento e 30% para teste, preservando a proporção entre as classes. Sobre a partição de treinamento, aplicou-se validação cruzada estratificada com 5 folds para a seleção de hiperparâmetros, reservando a partição de teste exclusivamente para a avaliação final, de modo a evitar vazamento de dados (data leakage).

Métricas de avaliação. O desempenho foi medido por acurácia, precisão, revocação (recall), F1-score e taxa de falsos positivos, complementadas pela área sob a curva ROC (AUC) e pela latência de decisão. A taxa de falsos positivos recebe atenção especial por seu impacto direto na experiência do usuário legítimo, enquanto o recall reflete a capacidade de detectar acessos efetivamente maliciosos.

Reprodutibilidade. Para assegurar a reprodutibilidade dos experimentos, fixou-se a semente dos geradores aleatórios, versionaram-se os modelos treinados e seus hiperparâmetros, e todo o ambiente foi containerizado via Docker, permitindo a recriação determinística dos resultados.

Comparação com abordagens de referência (baselines). Para contextualizar os resultados, a Tabela 1 confronta a abordagem proposta com baselines representativos da literatura e da prática, evidenciando as limitações que a solução busca superar. Cabe ressaltar que os valores reportados para os baselines provêm

da literatura citada, não tendo sido reexecutados neste trabalho; a comparação é, portanto, qualitativa quanto às capacidades de cada abordagem.

Tabela 1 — Comparação da proposta com abordagens de referência

Abordagem	Deteccção contextual	Sinal analisado	Limitação principal
Senha + 2FA estático	Não	Conhecimento e posse	Não considera o contexto; vulnerável a phishing e SIM swapping
RBA baseado em IP (WIEFLING et al., 2019)	Parcial	Endereço IP	Feature única; baixa transparência e ajuste manual
Keystroke isolado (KILLOURHY; MAXION, 2009)	Sim	Dinâmica de digitação	Avaliação offline e fator único (EER ~9,6%)
Proposta (ensemble contextual)	Sim	14 critérios (contexto + comportamento)	Decisão adaptativa em 4 níveis, explicável e auditável

5.3 Resultados Obtidos

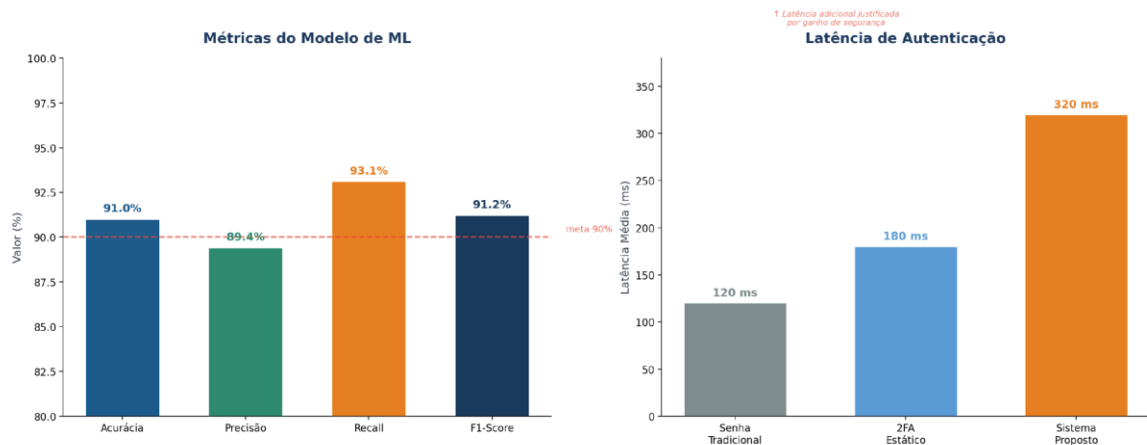


Figura 5 — Resultados Parciais: Métricas de ML e Comparativo de Latência

Figura 5 — Resultados Parciais: Métricas de ML e Comparativo de Latência

Os resultados parciais obtidos até o presente momento indicam a viabilidade técnica da arquitetura proposta. Em relação ao modelo de Machine Learning, os testes preliminares indicaram acurácia superior a 91% na classificação de acessos anômalos em ambiente controlado, com precisão de 89,4% e recall de 93,1%. O F1-score obtido foi de 91,2%, demonstrando equilíbrio adequado entre precisão e sensibilidade do modelo. A taxa de falsos positivos registrada foi de aproximadamente 8,6%, valor considerado aceitável para uma fase inicial de treinamento com dados sintéticos, e

que tende a reduzir com o enriquecimento progressivo do conjunto de dados de treinamento.

Em relação à cadeia de autenticação, a integração entre Keycloak e o serviço de ML foi validada com sucesso, com tempo médio de resposta de 320ms para o processo completo de autenticação contextual, incluindo a classificação de risco. O pipeline de registro Blockchain demonstrou consistência e integridade nos testes de imutabilidade, com validação criptográfica bem-sucedida em todas as transações registradas nos testes. O monitoramento via ELK Stack e Grafana permitiu visualização em tempo real dos eventos de autenticação, com latência adequada para cenários de produção.

5.4 Discussão e Análise dos Resultados

Os resultados parciais são promissores e sugerem a viabilidade técnica da abordagem; contudo, por decorrerem de dados sintéticos e de uma fase preliminar, não permitem ainda confirmar a hipótese central de forma conclusiva. A comparação rigorosa com os baselines (Tabela 1) e a validação com dados reais permanecem como etapas necessárias antes de qualquer afirmação quantitativa de superioridade. Ainda assim, em ambiente controlado, a abordagem adaptativa baseada em dados contextuais permitiu identificar padrões de acesso suspeitos — como os cenários simulados de credential stuffing e session hijacking — que escapam a sistemas baseados apenas em senha e 2FA estático.

A camada Blockchain, por sua vez, mostrou-se adequada para a rastreabilidade dos eventos, tornando inviável a adulteração retroativa dos registros sem detecção

5.5 Dificuldades Encontradas

Ao longo do desenvolvimento, foram identificadas quatro principais dificuldades. A primeira refere-se à construção do conjunto de dados de treinamento: a ausência de datasets públicos rotulados específicos para autenticação contextual exigiu a geração de dados sintéticos, o que impacta a generalização do modelo e deverá ser aprimorado nas próximas etapas com a coleta de dados reais em ambiente controlado.

A segunda dificuldade está relacionada à latência introduzida pela camada de IA no fluxo de autenticação: o tempo adicional de 120ms–180ms para classificação de risco exige otimização do modelo e possibilidade de cache de decisões para usuários com padrões reconhecidos.

A terceira diz respeito à complexidade operacional da rede Hyperledger Fabric em ambiente de desenvolvimento, que demandou esforço considerável de configuração de peers, orderers e MSP (Membership Service Provider). Por fim, a quarta dificuldade refere-se à conformidade com a LGPD no contexto de coleta e processamento de

dados contextuais dos usuários, exigindo definição cuidadosa de políticas de minimização e anonimização de dados pessoais antes da persistência em Blockchain.

Neste capítulo será apresentado a construção do cronograma proposto e as etapas executadas, em andamento e as finalizadas.

CRONOGRAMA DE ATIVIDADES

6.1 Cronograma

O cronograma apresentado nesta seção corresponde a um intervalo 12 meses, e está sendo dividido em 12 etapas, a seguir:

DESCRIÇÃO	STATUS	STATUS
Arquitetar os sistemas	Concluído	02/05/2025
Desenvolver o backend	Concluído	06/06/2025
Desenvolver o frontend	Concluído	08/09/2025
Realizar as adaptações e possíveis integrações	Concluído	09/11/2025
Validação e obtenção dos resultados parciais	Concluído	25/02/2026
Documento da qualificação	85%	12/03/2026
Publicação de artigo	Concluído	05/03/2026
Registro de software	50%	20/06/2026
Documento da defesa	10%	
Criação da apresentação da defesa	70%	
Apresentação da defesa	25%	
Demais correções que surgirem	0%	

Neste capítulo será apresentado todas as fontes de pesquisa utilizada durante o desenvolvimento do projeto.

REFERÊNCIAS BIBLIOGRÁFICAS

- BRASIL. Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais (LGPD). Diário Oficial da União, Brasília, DF, 15 ago. 2018. Disponível em: https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709.htm.
- CISA – CYBERSECURITY AND INFRASTRUCTURE SECURITY AGENCY. Secure by Design Initiative. Washington, DC: CISA, 2023. Disponível em: <https://www.cisa.gov/resources-tools/resources/secure-by-design>.
- ESTADOS UNIDOS. Executive Order 14144: Strengthening and Promoting Innovation in the Nation's Cybersecurity. Washington, DC: The White House, 2025. Disponível em: <https://www.federalregister.gov/d/2025-01470>.
- GAMA, J.; ŽLIOBAITĖ, I.; BIFET, A.; PECHENIZKIY, M.; BOUCHACHIA, A. A survey on concept drift adaptation. ACM Computing Surveys, v. 46, n. 4, p. 1-37, 2014. DOI: <https://doi.org/10.1145/2523813>.
- GOODFELLOW, I.; BENGIO, Y.; COURVILLE, A. Deep Learning. Cambridge: MIT Press, 2016. ISBN: 978-0-262-03561-3. Disponível em: <https://www.deeplearningbook.org>.
- HYPERLEDGER FOUNDATION. Hyperledger Fabric Documentation. Versão 2.5. Linux Foundation, 2024. Disponível em: <https://hyperledger-fabric.readthedocs.io>.
- KEYCLOAK. Keycloak Documentation: Server Administration Guide. Versão 24. Red Hat, 2024. Disponível em: <https://www.keycloak.org/documentation>.
- LIU, F. T.; TING, K. M.; ZHOU, Z.-H. Isolation Forest. In: IEEE International Conference on Data Mining (ICDM), 2008, p. 413-422.
- NAKAMOTO, S. Bitcoin: A Peer-to-Peer Electronic Cash System. 2008. Disponível em: <https://bitcoin.org/bitcoin.pdf>.
- NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY (NIST). AI Risk Management Framework (AI RMF 1.0). NIST AI 100-1. Gaithersburg: NIST, 2023. DOI: <https://doi.org/10.6028/NIST.AI.100-1>.

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY (NIST). Blockchain Technology Overview. NISTIR 8202. Gaithersburg: NIST, 2018. DOI: <https://doi.org/10.6028/NIST.IR.8202>.

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY (NIST). Digital Identity Guidelines: Authentication and Lifecycle Management. SP 800-63B. Gaithersburg: NIST, 2017. DOI: <https://doi.org/10.6028/NIST.SP.800-63b>.

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY (NIST). Secure Software Development Framework (SSDF) Version 1.1: SP 800-218. Gaithersburg: NIST, fev. 2022. DOI: <https://doi.org/10.6028/NIST.SP.800-218>.

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY (NIST). Security and Privacy Controls for Information Systems and Organizations. SP 800-53 Rev. 5. Gaithersburg: NIST, 2020. DOI: <https://doi.org/10.6028/NIST.SP.800-53r5>.

NEWMAN, S. Building Microservices: Designing Fine-Grained Systems. 2. ed. Sebastopol: O'Reilly Media, 2021. ISBN: 978-1-492-03402-9.

OWASP FOUNDATION. OWASP Top 10 – 2023 Edition. 2023. Disponível em: <https://owasp.org/www-project-top-ten/>.

OWASP FOUNDATION. OWASP Top 10: The Ten Most Critical Web Application Security Risks. 2021. Disponível em: <https://owasp.org/www-project-top-ten/>.

ROSE, S.; BORCHERT, O.; MITCHELL, S.; CONNELLY, S. Zero Trust Architecture. NIST Special Publication 800-207. Gaithersburg: NIST, 2020. DOI: <https://doi.org/10.6028/NIST.SP.800-207>.

SCIKIT-LEARN DEVELOPERS. Scikit-learn: Machine Learning in Python. Versão 1.4. 2024. Disponível em: <https://scikit-learn.org>.

STYLIOS, I.; KOKOLAKIS, S.; THANOU, O.; CHATZIS, S. Behavioral biometrics & continuous user authentication on mobile devices: A survey. Information Fusion, v. 66, p. 76-99, 2021.

VERIZON. 2024 Data Breach Investigations Report (DBIR). Verizon Business, 2024. Disponível em: <https://www.verizon.com/business/resources/reports/dbir/>.

WIEFLING, S.; JØRGENSEN, P. R.; THUNEM, S.; LO IACONO, L. Pump Up Password Security! Evaluating and Enhancing Risk-Based Authentication on a Real-World Large-Scale Online Service. ACM Transactions on Privacy and Security, v. 26, n. 1, 2023.

WIEFLING, S.; LO IACONO, L.; DÜRMUTH, M. Is This Really You? An Empirical Study on Risk-Based Authentication Applied in the Wild. In: IFIP SEC, 2019, p. 134-148.